

Supplementary Material:

Closing the Security Activation Gap: A Security-by-Design Methodology for IoT Ecosystems and Its Empirical Validation in a DC Smart Microgrid

S1. Methodology Parameterized Specification: SMG Case Study

This document provides the full parameterized specification of all four phases for the SMG case study, complementing the condensed traceability in the main text’s Tables 10 and 11. Each row in Tables S1–S4 corresponds to a methodology parameter defined in the methodology’s process tables. Codes with an additional digit (e.g., 4.1.2.1) refine a stage-level process (as cited in the main text) into its implementation-specific components; the parent code is the methodology-level process that those refinements collectively satisfy.

References

- Fagan, M., Marron, J., Brady, K., Cuthill, B., Megas, K., Herold, R., 2021. IoT Device Cybersecurity Guidance for the Federal Government: Establishing IoT Device Cybersecurity Requirements. NIST Special Publication 800-213. National Institute of Standards and Technology (NIST). Gaithersburg, MD. doi:[10.6028/NIST.SP.800-213](https://doi.org/10.6028/NIST.SP.800-213).
- Stanicek, O., 2022. esp32_puflib: An SRAM-based physical unclonable function library for the ESP32 microcontroller family. Software library, ESP-IDF component, https://github.com/staniond/esp32_puflib.
- UK Government Security, 2024. Secure by design principles. <https://www.security.gov.uk/guidance/secure-by-design/principles/>. Accessed: 30 April 2024.

Table S1: Phase A, Stage 1: Organizational aspects — SMG application.

Process ID	Parameter	SMG Value
1.1	Problem statement	Manage distributed DC renewable energy generation, storage, and consumption across 2 co-located laboratory nodes; provide global coordination and real-time monitoring without centralized national grid
1.1.1	Cost-benefit justification	Energy losses (imbalanced generation/demand) eliminated; TRL 3 budget: 2× ESP32 NodeMCU + RPi4 + commercial solar adapters + AGM batteries + IBFIA SSRs
1.1.2	Entities involved	5: IoT nodes (2× ESP32), IoT server (RPi4), users (operators), administrators (researcher), DC bus (physical)
1.3.1	Development iteration (TRL)	ITER 1 target: TRL 3 (proof of concept with physical elements, controlled laboratory)
1.4.1	Criticality classification	Critical infrastructure — electrical energy; high-security tier selected (Stage 1.4.1)
1.4.2	Technological sovereignty	No cloud services; all computation on ESP32 (local) and RPi4 (global); open-source software only
1.4.3	Data sovereignty	Self-hosted RPi4 server; no third-party cloud; all sensor data stored locally
1.4.4	Access control policy	Token-based; nodes: POST sensor data only; users: GET monitoring; admins: full configuration and entity management
1.4.5	Communication policy	Mandatory application-layer encryption (AES-256-GCM); TCP over WiFi 802.11 b/g/n; no plaintext data channel
1.4.6	Applicable guidelines	Secure-by-Design principles (UK Government Security, 2024); NIST IoT security (Fagan et al., 2021); OWASP IoT Top 10

Table S2: Phase B, Stages 2–3: Architecture and service design — SMG application.

Process ID	Parameter	SMG Value
2.1.4	Communication topology	Centralized (hub-and-spoke): both nodes communicate exclusively with primary server; no node-to-node direct communication
2.1.5	Communication infrastructure	WiFi 802.11 b/g/n; ESP32 built-in; TCP sockets; RPi4 configured as WiFi AP (SSID: SMG_Primary; NetworkManager hotspot, 10.42.0.0/24 with gateway 10.42.0.1)
2.1.7	Processing topology	Fog: local 9-rule fuzzy EMS on each ESP32; global 27-rule security-aware fuzzy EMS on RPi4; commercial solar adapter handles droop and battery-charging voltage regulation autonomously
2.1.8	Entity hierarchy	IoT Nodes < Users < Administrators
2.2.2	Authentication mechanism	Nonce-bound asymmetric (ECDSA) device proof + per-node symmetric (SHA-256 hash-reconstruction) server proof, both PUF-seeded, for IoT nodes; plain SHA-256 hash for users/admins (not a salted, slow key-derivation function; see main text Limitations)
2.2.3	Root of Trust process	PUF-seeded scheme (<code>esp32_puflib</code>): enrollment via RTC-SRAM measurement (admin workstation) → non-secret mask/ECC helper data to NVS (USB serial) → HKDF-derived EC key pair → device public-key registration and per-node server-verifier provisioning → per-boot response reconstruction and mutual identification
2.2.4	Secure communications	AES-256-GCM (ESP-IDF <code>mbedtls</code> / <code>esp_aes</code>) with 12-byte random nonces per message, keyed from the PUF-derived session key; no message-level cryptographic chain (design trade-off, see main text Limitations); no TLS certificate management needed on constrained devices
3.1.1	Services defined	4: sensor data ingestion (nodes→server), EMS coordination (server→nodes), authentication API (all entities), monitoring dashboard (server→users)
3.2.1	Access control	RBAC via session token type; API endpoints enforce entity class; nodes POST-only to own data endpoint
3.2.2	Identity storage	ESP32: NVS flash partition (separate from firmware, survives updates, JTAG-disabled for TRL 5+); Server: PostgreSQL-equivalent for SMG + <code>node_registry.json</code> for provisioning records

Table S3: Phase C, Stages 4–5: Implementation technologies and functional elements — SMG application.

Process ID	Parameter	SMG Value
4.1.1	TRL 3 criteria met	Physical node operational; mutual authentication functional; all applicable functional tests passed (Table 15, main text). PWM energy control and sensor-data logging are specified by the physical hardware (Table S3, process 5.1.2) but not yet exercised by the current C/ESP-IDF firmware, which implements only identity/RoT/secure-communication (see main text Limitations)
4.1.2.1	Node platform	ESP32 + C/ESP-IDF (v5.4.2, per the flashed firmware build log): built-in WiFi, SHA-256 HW acceleration, NVS; <code>esp32_puflib</code> (Stanicek, 2022) linked directly as a native ESP-IDF component (no language-runtime wrapper needed); identity/RoT/communication firmware (<code>smg_puf_rot_node</code>) builds cleanly under ESP-IDF; flashed, enrolled, and bench-validated end-to-end on SMG_NODE_01 ($N = 30$ real hard-reset trials, 30/30 success) — SMG_NODE_02 bench status still pending
4.1.2.2	Cryptography	HKDF-SHA256 (RFC 5869) derives a P-256 (secp256r1) key pair from the PUF response (<code>esp32_puflib</code>); device authenticates via ECDSA signature over a server-issued nonce (<code>mbedtls</code>), verified against the registered public key; server authenticates via a per-node SHA-256 hash-reconstruction proof; session-key derivation $Key_{ab} = \text{SHA-256}(V_B \ N_A \ N_B)$ (<code>rot_session.c</code>); AES-256-GCM via ESP-IDF <code>mbedtls/esp_aes</code>
4.1.3	Communication protocol	TCP over WiFi 802.11 b/g/n; application-layer nonce-based mutual authentication protocol (implementation-specific Stage 4 choice, presented as part of this work’s own case study)
4.2.1	Vulnerability mitigations	ESP-IDF v5.4.2 pinned (per the flashed firmware build log); WiFi credentials in NVS; all AES-GCM nonces and challenge values from <code>esp_fill_random()</code> (ESP-IDF HW RNG); no persistent device secret exists to protect, since the device’s private key is derived fresh each boot and never stored; JTAG disable deferred to TRL 5+
5.1.1	Primary agent (RPi4)	Python: <code>server.py</code> , <code>auth_service.py</code> , <code>ems_coordinator.py</code> (27-rule security-aware fuzzy), <code>data_store.py</code> ; <code>puf_server.py</code> + <code>rot_challenge_service.py</code> (PUF-based mutual authentication challenge service, separate port)
5.1.2.1	Node power supply	DC-DC buck converter (12V→5V) per node from local battery; isolates ESP32 from shared DC bus; $\approx 90\%$ efficiency vs. $\approx 27\%$ for LDO at 12 V (avoids ≈ 3.8 W peak dissipation)
5.1.2.2	Identity storage	ESP32 NVS: <code>node_id</code> , <code>node_uuid</code> , PUF stable-bit mask, PUF ECC helper data, <code>wifi_ssid</code> , <code>wifi_pass</code> — none present in <code>config.json</code> or firmware binary; no raw key or PUF response is ever written to NVS
5.1.2.3	Node firmware modules	C/ESP-IDF application <code>smg_puf_rot_node</code> (<code>app_main.c</code> , <code>rot_identity.c/h</code> , <code>rot_session.c/h</code> ,

Table S4: Phase D, Stages 6–7: Deployment, operation, and maintenance — SMG application.

Process ID	Parameter	SMG Value
6.1.3	RoT execution	PUF-based scheme, executed and validated on SMG_NODE_01 (1/2 nodes; SMG_NODE_02 pending): admin runs <code>enroll_puf()</code> → mask/ECC helper data written to ESP32 NVS → server verifier registration via <code>register_puf_node.py</code> → per-boot reconstruction and nonce-bound mutual identification confirmed over $N = 30$ real hard-reset trials (30/30 success)
6.2.1	Functional test coverage	8 tests: boot (FT-01), WiFi from NVS (FT-02), P2 handshake (FT-03), P3 session (FT-04), P4 chain (FT-05), fuzzy EMS (FT-06), ADC saturation (FT-07), degraded mode (FT-08); 100% pass rate
6.2.2	Tamper verification	NVS parameter tampering confirmed as authentication failure (single targeted negative test; full penetration testing deferred to ITER 2)
7.1.1	Monitoring (Stage 7.1.1)	Per-node real-time: V_{bus} , I_{bus} , P_{bus} , V_{gen} , I_{gen} , P_{gen} , D_{pwm} ; authentication status; session history (evidentiary log, no cryptographic chain, see main text Limitations); heap free
7.1.4	Maintenance cycles	One maintenance moment (SMG_NODE_01): an enrollment-state-confusion bug causing an unbounded re-enrollment loop on reconstruction retry, identified and fixed via code-level revision (M2) prior to the $N = 30$ bench trial. M1 and M3 not triggered at TRL 3; SMG_NODE_02 maintenance-cycle evidence remains pending.
7.2.1	Anomaly detection	Per-node trust score (float 0.0–1.0): initialized 0.80 on successful P2 identification; -0.30 on P3 authentication-tag failure; -0.40 on V_{bus} anomaly; UNTRUSTED (< 0.30) ⇒ TCP dropped; recovery requires re-auth
7.2.2	Update elements	OTA update requires admin token + firmware signature (deferred to ITER 2)
7.2.3	Incident response	Auth failures logged; > 3 consecutive failures ⇒ quarantine
7.2.4	Security-aware EMS	Global fuzzy EMS (27 rules) on RPi4 accepts the per-node trust score from 7.2.1 as a third input alongside voltage tracking error and bus current, producing security-aware energy management without a separate intrusion response layer